

[공공·기술] 시민 알권리 • 공공기관 웹 보안 점검

용인시의회 홈페이지, 주요 웹 보안 헤더 **응답 미관찰**

HSTS·CSP·X-Frame-Options 등 **6종 응답 미관찰** ... KISA 전자정부 가이드 기준 개선 권고



【리드】 용인시의회 홈페이지(council.yongin.go.kr)에서 브라우저 수준 심층 방어를 담당하는 핵심 HTTP 보안 헤더 다수가 응답에서 **관찰되지 않았다**. 본지가 2026-04-18 공개 정보만을 대상으로 수동 조사한 결과다. 전송 계층과 쿠키 기본 위생은 갖췄으나, **HSTS·CSP·X-Frame-Options 등 6종 헤더**가 외부 응답에서 관찰되지 않아 클릭재킹·다운그레이드·스크립트 주입 피해 확산 경로가 외부 관측상 차단되지 않은 상태로 남아 있다. 기관 내부 레이어에서의 구현 여부는 본 취재 범위 밖이며, 본지는 같은 날 기관에 반론 요청을 발송했다.

경인블루저널 박용환 기자 입력 2026.04.18 • 최초 보도

▲ 취재 원칙. 본 기사는 공개 정보 기반의 수동 취재다. 취약점 스캐너 실행·페이로드 주입·인증 우회 등 능동적 점검은 수행하지 않았다. 따라서 "관찰되지 않음"은 외부 응답 레이어에 보이지 않는다는 뜻이며, 기관 내부 구성까지 단정하지 않는다.

반론권 보장. 본지는 2026-04-18 14:00 KST 용인시의회 사무처 대표번호(031-6193-3967) 및 공식 이메일 경로로 취재 내용 확인 및 반론 요청을 발송했다. 보도 전 **24시간 답변 기회**를 제공했으며, 지정 시한까지 회신이 도착하지 않아 공익성을 고려해 선행 보도한다. 기관 답변 수신 시 본 지면에

TABLE OF CONTENTS

독자별 추천 읽기 — 기관 담당자: 00 → 04 → 05 · 기술 독자: 00 → 01 → 02 · 일반 독자: 00 → 05

00 기사 요약·세 줄 정리

01 관찰 결과 일람표

02 영역별 취재 상세 (A-F)

03 등급 체계

04 개선 권고 8건

05 취재 원칙·신고 경로

06 본 취재의 한계

AP 법적 근거·참고자료

DOCKET № 001 - SUBJECT

OBJECT

`https://council.yongin.go.kr/`

OBSERVED

2026-04-18 05:37 UTC (14:37 KST) 관찰 · 2026-04-18 14:00 KST 반론 요청 발송

취재

경인블루저널 박용환 기자 · heisenbug0306@gmail.com

INSTRUMENTS

WebFetch · `curl -sSI` · `openssl s_client` · `nslookup` · CT 로그 조회

근거법

헌법 제21조(언론의 자유) · 정보통신망법 제48조 · 정보통신기반 보호법 · 형법 제310조(위법성 조각)

STANDARDS

KISA · OWASP Top 10 2021 · ASVS L1 · Mozilla · RFC 9116

00

기사 요약 · EXECUTIVE SUMMARY

세 줄로 정리한
취재 결과.

01

HTTPS · 인증서 · 쿠키 보안 플래그(`Secure` / `HttpOnly`) 등 기본 위생은 갖춰져 있다.

02

반면 최신 HTTP 보안 헤더(HSTS·CSP·X-Frame-Options 등)가 응답에서 보이지 않아, 브라우저 수준 심층 방어가 약한 편이다.

03

security.txt 부재로 취약점을 신고할 창구가 외부에 표시돼 있지 않다. 책임 있는 공개 경로 정비를 권고한다.

01

01 · 관찰 결과 일람표

응답에서 확인된 것,
보이지 않은 것.

영역

관찰 결과

권고 기준

등급

HTTPS 사용

200 OK (HTTPS)

충족

양호

영역	관찰 결과	권고 기준	등급
TLS 버전	TLSv1.2 협상 확인 · TLSv1.3 단정 불가	TLSv1.3 기본 협상	INFO
TLS 암호 스위트	ECDHE-RSA-AES256-GCM-SHA384 (PFS)	충족	양호
인증서	GlobalSign GCC R6 AlphaSSL CA 2025 발급, 유효	충족	양호
쿠키 Secure	있음	충족	양호
쿠키 HttpOnly	있음	충족	양호
쿠키 SameSite	관찰되지 않음	Lax/Strict 명시	LOW
Strict-Transport-Security	관찰되지 않음	필수 권고	MEDIUM
Content-Security-Policy	관찰되지 않음	필수 권고	MEDIUM
X-Frame-Options / frame-ancestors	관찰되지 않음	필수 권고	MEDIUM
X-Content-Type-Options	관찰되지 않음	ASVS L1 요건	MEDIUM
Referrer-Policy	관찰되지 않음	권고	LOW
Permissions-Policy	관찰되지 않음	권고	LOW
Cross-Origin-* 헤더군	관찰되지 않음	기밀 페이지 권고	INFO
Server / X-Powered-By	노출되지 않음	충족	양호
/robots.txt	존재, 2개 경로 Disallow	정보성	INFO
/sitemap.xml	없음(404)	보안 이슈 아님	INFO

영역	관찰 결과	권고 기준	등급
<code>/.well-known/security.txt</code>	없음(404)	RFC 9116 권고	LOW
SPF (yongin.go.kr)	관찰되지 않음	KISA 이메일 보안 권고	MEDIUM
DMARC (_dmarc.yongin.go.kr)	관찰되지 않음	공공기관 사칭 방어	MEDIUM

"관찰되지 않음"은 외부 응답에서 보이지 않았다는 뜻이며, 내부 구성에 따라 다를 수 있다. 특히 SPF/DMARC는 상위 도메인 정책과 메일 서비스 운영 여부에 따라 해석이 달라진다.

02

02 · 영역별 취재 상세

영역별로 확인된 사실,
근거와 함께.



전송 계층/TLS

관찰된 핸드셰이크

- 인증서 주체: CN=*.yongin.go.kr · SAN: *.yongin.go.kr , yongin.go.kr
- 발급자: GlobalSign GCC R6 AlphaSSL CA 2025 → GlobalSign Root CA - R6 체인
- 서명: RSA-SHA256, 공개키 RSA 2048비트
- 유효기간: 2026-03-04 ~ 2027-04-05 (관찰 시점 기준 유효)
- 핸드셰이크: TLSv1.2 , Cipher ECDHE-RSA-AES256-GCM-SHA384 , Temp Key ECDH prime256v1 256 bits
- ALPN: No ALPN negotiated — HTTP/2 단정 불가 (HTTP/1.1만 관찰)
- 서버 IP: 27.101.119.45 (KT/Kornet 대역)
- **HSTS 헤더 없음** — HTTPS 강제는 애플리케이션 리다이렉션에 의존 추정

권고

- **HSTS 활성화.** Strict-Transport-Security: max-age=31536000; includeSubDomains 다운그레이드 방어 핵심.

※ **preload** 지시어는 별도 검토 필요 — hstspreload.org 등재 시 모든 *.yongin.go.kr 서브도메인이 브라우저 벤더 목록에 영구 HTTPS 강제되며 제거 절차는 수개월이 소요된다. 내부 HTTP 연동 시스템 사전 점검 후 결정할 것.

- **TLSv1.3 활성화 확인.** 외부 관찰로 단정 불가. 내부 구성 점검 권고.
- **와일드카드 인증서 정책 재검토.** *.yongin.go.kr 공용 사용은 한 서브도메인 키 유출이 전체 서비스로 번질 수 있다. 고위험 서비스 분리 검토.

B

HTTP 보안 헤더

응답 원문 (VERBATIM)

```
COUNCIL.YONGIN.GO.KR · RESPONSE · 2026-04-18 05:37 UTC
```

```
HTTP/1.1 200
Set-Cookie: JSESSIONID=<redacted>; Path=/; Secure; HttpOnly
Content-Type: text/html; charset=UTF-8
Content-Language: ko-KR
Transfer-Encoding: chunked
Date: Sat, 18 Apr 2026 05:37:21 GMT
```

응답에 없었던 헤더

- Strict-Transport-Security
- Content-Security-Policy
- X-Frame-Options (및 CSP frame-ancestors)
- X-Content-Type-Options
- Referrer-Policy, Permissions-Policy
- Cross-Origin-Opener/Embedder/Resource-Policy
- Server, X-Powered-By — 노출되지 않음 (양호: 버전 지문 미공개)

해석

- **HSTS 부재.** 초기 HTTP 접근 시 공용 Wi-Fi 등 중간자 다운그레이드·스트리핑 공격 경로가 이론적으로 존재.
- **CSP 부재.** 혹여 XSS가 존재할 경우, 브라우저 측 완화책이 비어 있어 피해 확산이 빠르다.
- **X-Frame-Options / frame-ancestors 부재.** 용인시의회 페이지를 타 사이트에서 <iframe>으로 임베드해 클릭재킹 수행 가능.
- **X-Content-Type-Options 부재.** 업로드 / 정적 파일 구간에서 MIME 스니핑 공격 여지.
- **Referrer-Policy 부재.** 외부 링크 이동 시 내부 URL/쿼리가 전체 유출될 수 있음.
- **Permissions-Policy 부재.** 의도치 않은 카메라·마이크·지오로케이션 권한 경로.

RECOMMENDED RESPONSE HEADERS

```
Strict-Transport-Security: max-age=31536000; includeSubDomains
Content-Security-Policy: default-src 'self'; img-src 'self' data: https;;
                        script-src 'self'; frame-ancestors 'self'
X-Content-Type-Options: nosniff
Referrer-Policy: strict-origin-when-cross-origin
Permissions-Policy: camera=(), microphone=(), geolocation=()
```

CSP는 인라인 스크립트·3rd-party 위젯 사용 현황에 따라 `Report-Only` → `Enforce` 로 점진적 조정. 실 배포 전 스테이징 검증 권고.



쿠키 위생

관찰

SET-COOKIE

Set-Cookie: JSESSIONID=...; Path=/; Secure; HttpOnly

- Secure , HttpOnly — 있음 (양호)
- SameSite — 없음

해석

- SameSite 미지정은 브라우저 기본값 의존. 최신 Chromium은 Lax 기본이나, 구형 클라이언트에서 동작이 달라 CSRF 심층 방어가 불안정.
- JSESSIONID 라는 쿠키 이름은 Java Servlet 컨테이너(전자정부 표준프레임워크 / Tomcat 등) 기반 추정 단서일 뿐, 취약점 단정 근거는 아님.

권고

- 세션 쿠키에 SameSite=Lax (워크플로에 따라 Strict) 명시
- 로그인 구간은 짧은 TTL 토큰 + 세션 고정(fixation) 방지 회전 구성 점검(내부 검토)

D

공개파일·경로

관찰

```
/ROBOTS.TXT - 200
.....
User-agent: *
Disallow: /kr/open/bbsRequest.do
Disallow: /kr/open/search.do
```

- /sitemap.xml → 404
- /.well-known/security.txt → 404

해석

- robots.txt 의 Disallow 경로는 크롤링 예외 선언이지 접근 제어 경계가 아니다. 공격자는 이 경로 존재 자체를 단서로 활용할 수 있다. 실제 접근 제어는 서버 측 권한 검증으로만 보장된다(본지 취재에서는 해당 경로에 접근하지 않음).
- security.txt 부재 — 외부에서 우연히 취약점을 발견한 이용자가 기관 담당자를 찾기 어렵다. 대안은 KISA 보호나라 신고.

권고 (SECURITY.TXT 예시)

```
/.WELL-KNOWN/SECURITY.TXT
.....
# RFC 9116
Contact: mailto:<담당부서 이메일>
Expires: 2027-04-18T00:00:00+09:00
Preferred-Languages: ko, en
Policy: https://council.yongin.go.kr/security-policy
```


E

클라이언트 사이드 표면

관찰 (HTML 소스 수준)

- `<meta charset="utf-8">`, `<meta name="viewport" content="width=device-width, initial-scale=1.0">`
- 푸터: `COPYRIGHT © 2021 YONGIN CITY COUNCIL`, 주소·전화 노출 — 기관 공개 정보이므로 문제 없음
- 외부 도메인 리소스: `facebook.com/yicouncil`, `youtube.com/channel/...`, `twitter.com/yicouncil`, `clive.yongin.go.kr` (생중계), `elis.go.kr` (법령 정보)
- 웹접근성 인증 배지 → `webwatch.or.kr`
- 프레임워크 단서: 한국 전자정부 표준프레임워크(egovframe) 패턴으로 추정(단정 아님)
- `SRI( integrity= )` 속성 적용 여부는 관찰 스니펫 범위에서 확인 어려움 — 전체 자산 단위 확인 필요

해석 · 권고

- 외부 트래커 스크립트는 이 세션에서 뚜렷하게 보이지 않았으나, 로딩되는 모든 외부 리소스에 **SRI + CSP** `script-src` 화이트리스트 적용 점검 권고.
- `clive.yongin.go.kr` (생중계), `elis.go.kr` 등 연관 시스템은 본 기사 범위 밖이다. 별도 취재가 필요할 수 있다.

F

DNS / 이메일 스푸핑 방어

NSLOOKUP 결과

- `council.yongin.go.kr` → A `27.101.119.45`
- `yongin.go.kr` MX 조회: MX 레코드 직접 응답 없이 권한 NS(`ns.gcc.go.kr`) 만 반환
- `yongin.go.kr` TXT: "`_globalsign-domain-verification=...`" — **GlobalSign** 인증서 발급 소유 검증 값 · **SPF가 아님**
- `_dmarc.yongin.go.kr` TXT: 별도 DMARC 레코드 관찰되지 않음 (SOA/NS 정보 만 반환)
- `_dmarc.council.yongin.go.kr` : Non-existent domain
- 권한 NS: `ns.gcc.go.kr` (정부 통합 DNS) — 정상

해 석

- `yongin.go.kr` 도메인에서 **SPF · DMARC 레코드가 확인되지 않았다**. 이는 해당 도메인을 발신자로 위조한 피싱 메일을 수신 측에서 자동 필터링하기 어려운 상태를 의미한다.
- `council.yongin.go.kr` 서브도메인에서 이메일 발송이 없다면 직접 영향은 낮 으나, `yongin.go.kr` 조직 차원에서 `v=DMARC1; p=reject; rua=mailto:...` 엄격 정책 적용을 권한다. 용인시 정보보안 부서와 함께 판단할 사안.
- **참고.** DNS는 리졸버 캐시 · 분할 DNS 등으로 외부 관측이 내부 운영과 다를 수 있 다. 본지 취재는 공개 리졸버 응답을 근거로 한다.

03

03 · 등급 체계

본기사의
위험도 분류 기준.

등급

의미

INFORMATIONAL

관찰된 사실 또는 양호 항목. 조치 불필요 혹은 유지 권장.

LOW

현행 기준 대비 소폭 개선 필요. 단독으로는 실질 피해 가능성 낮음.

MEDIUM

일반적인 보안 권고 기준 미충족. 외부 관찰만으로는 실제 피해 단정 불가이나 심층 방어 강화 필요.

high / critical

본 기사에서는 사용하지 않음. 능동 점검 없이 단정 불가.

분류 근거. 본 기사의 **medium / low** 분기는 **OWASP Secure Headers Project**의 "Headers That Should Be Set" 기준을 따른다. 피해 확산 경로를 차단하는 헤더(HSTS·CSP·X-Frame-Options), ASVS L1 명시 요건(X-Content-Type-Options), 공공기관 피싱 방어 기준(SPF·DMARC·KISA 이메일 보안 가이드)을 **medium**으로, 정보 유출 억제 헤더(Referrer-Policy·Permissions-Policy)를 **low**로 구분한다.

04

04 · 개선 권고

여덟 가지 권고 조치.

번호 순은 구현 용이성과 즉각 효과를 함께 고려한 실무 적용 순서이며 중요도 순과 다를 수 있다. 동일 등급 내 순서는 임의다. CSP는 준비 완료 시점에 최우선으로 당겨 처리할 것.

01

HSTS 헤더 적용

다운그레이드 공격 방어 · 비용 낮고 효과 큼

MEDIUM

02

X-Frame-Options / frame-ancestors

클릭재킹 방어

MEDIUM

03

X-Content-Type-Options: nosniff

MIME 스니핑 방어

LOW

04

Referrer-Policy / Permissions-Policy 기본값

리퍼러·권한 경로 통제

LOW

05

Content-Security-Policy 단계적 도입

Report-Only → Enforce 순으로

MEDIUM

06

세션 쿠키 SameSite 명시

CSRF 심층 방어

LOW

07

/.well-known/security.txt 게시

책임 있는 공개 창구 정비

LOW

08

yongin.go.kr SPF / DMARC 적용

상위 조직 정보보안 담당 협의

LOW

본 권고는 외부 관찰 기반 일반 권고이며, 실제 적용 전 내부 영향 평가와 스테이징 검증이 필요하다.

05

05 · 취재 · 보도 원칙 및 신고 경로

본지의 취재 원칙. 시민의 신고 경로.

EDITORIAL PRINCIPLES · 본지 취재 원칙

경인블루저널 공익 보도 원칙

- 01 **공익 보도.** 공공기관 웹사이트의 보안 위생은 시민 알권리와 직결된 공공의 이익 사안이다.
- 02 **수동 취재.** 본 기사는 공개 정보만을 조회하는 비침투적 취재에 한하며, 정보통신망법 제48조를 준수한다.
- 03 **반론권 보장.** 본지는 보도 전 기관에 **최소 24시간 답변 기회**를 제공하고, 접수한 반론·사실 확인 요청은 **72시간 내 본 지면에 반영**한다. 요청 접수처:
`heisenbug0306@gmail.com`.
- 04 **지속 모니터링.** 개선 조치 여부를 *Dossier №002* 후속 기사로 추적 보도한다.

일반 독자가 본 기사 이상의 의심 사항을 **우연히 발견한 경우, 직접 접근해 검증하지 말고** 아래 경로로 신고하는 것이 한국 법체계상 안전하다.

01

KISA 보호나라 취약점 신고센터

웹 — boho.or.kr. PoC는 필요한 최소 범위만 기술하고, 실제 악용 흔적이 남지 않도록 서술한다.

02

민·관 합동 취약점 신고포상제

KISA 주관. 공공기관 대상 취약점도 접수 가능.

03

용인시의회 사무처 직접 연락

공식 홈페이지 푸터의 대표번호 031-6193-3967 (경기도 용인시 처인구 중부대로 1199)로 연결 후 "정보보안 담당 부서" 안내 요청. 조직 차원 이슈(SPF/DMARC 등 `yongin.go.kr` 도메인 레벨)는 용인시청 정보통신과에도 별도 문의.

04

공식 security.txt 부재 관련

본 기사 제안대로 기관이 `/.well-known/security.txt` 를 게시하면, 향후 외부 신고 경로가 표준화된다.

신고 전에 취약점을 재현하기 위한 **추가 스캔·페이로드 주입**은 법적 위험이 있으므로 수행하지 않는다.

06

06 · 본 취재의 한계

본지 취재가 말하지 못한 것.

- L.01** 능동 점검 없음. 실제 인젝션 계열(SQLi / XSS / SSRF 등) 취약점 존재 여부는 본지 취재로 확인 불가.
- L.02** 단일 페이지 범위. 관찰은 / 메인 페이지와 소수 공개 파일에 한정. 내부 페이지·로그인 구간의 헤더·쿠키 동작은 다를 수 있다.
- L.03** 시점 의존. 2026-04-18 관찰 시점의 응답만을 근거로 한다. 이후 변경은 반영되지 않는다.

L.04 DNS 관측. 공개 재귀 리졸버(168.126.63.1 , KT DNS) 응답 기준. 권한 네임서버 직접 질의와 차이가 있을 수 있다.

L.05 TLSv1.3. 추가 탐지가 권한 정책상 차단되어 단정하지 않는다.

L.06 운영 계층 미관측. 본지 취재는 최종 응답 헤더만을 근거로 한다. WAF·L7 프록시·내부 정책 서버 등 운영 계층 구성은 확인하지 않았다. 기관 내부가 다른 계층에서 해당 통제를 구현했을 가능성은 배제하지 않는다.

AP

AP · 근거 및 참고자료

법적 근거와 참고 문헌.

APPENDIX A

법적 근거 요약

- 「정보통신망 이용촉진 및 정보보호 등에 관한 법률」 제48조. 정당한 접근권한 없이 정보통신망에 침입하거나 정보를 훼손·변경·위조하는 행위 금지. 위반 시 형사처벌.
- 「정보통신기반 보호법」. 주요정보통신기반시설에 대한 보호 의무 및 취약점 분석·평가 체계.
- 「개인정보 보호법」 제29조. 개인정보 처리자의 안전조치 의무 — 기술적·관리적 보호조치.

참고 링크

- KISA 보호나라 — boho.or.kr
- OWASP Top 10 (2021) — owasp.org/Top10
- OWASP Secure Headers Project — owasp.org/www-project-secure-headers
- Mozilla Web Security Guidelines — infosec.mozilla.org/guidelines/web_security
- RFC 9116 (security.txt) — rfc-editor.org/rfc/rfc9116
- 행정안전부 「전자정부 웹사이트 보안 가이드라인」 — 공공기관 웹 보안 위생이 행정 지침 준수 사안임을 뒷받침
- KISA 「공공기관 개인정보 침해 현황 통계」 — 공공기관 웹 보안 취약이 실질 시민 피해로 이어진 사례 집적

• — •

경인블루저널 박용환 기자

본 기사는 경인블루저널이 2026-04-18

공개 정보를 취재해 작성한 공익 보도다.

기관 반론 · 사실 확인 요청 접수: heisenbug0306@gmail.com

후속 기사(Dossier №002)로 조치 경과를 추적 보도한다.

— 경인블루저널 · DOSSIER №001 —